Week 1: Basic Web Application Reconnaissance

1. Objective

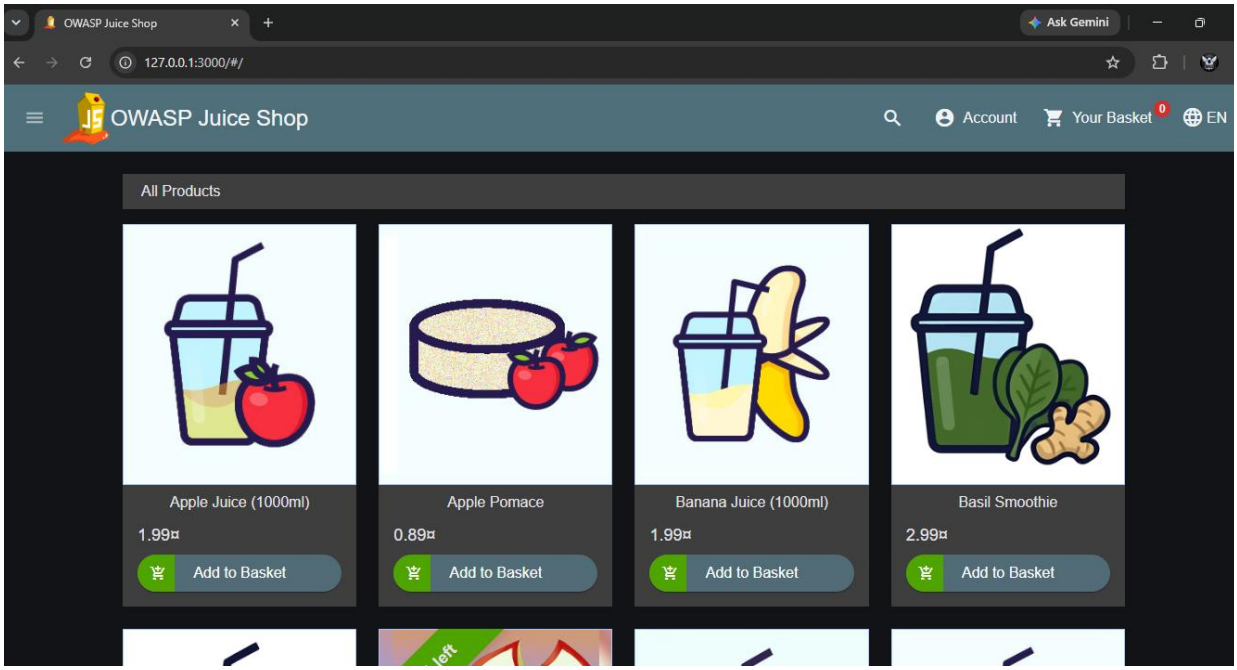
To explore the OWASP Juice Shop application and identify its main user-facing entry points as preparation for developing an automated web application security scanner.

2. Laboratory Environment

- Operating system: Windows with VMware
- Container platform: Docker
- Target application: OWASP Juice Shop
- Target URL: http://localhost:3000

3. Application Entry Points

1. Home page



What you can observe

- Navigation menu and product categories.
- Product listings, names, images and prices.
- Search bar.
- Login and shopping-basket links or icons.

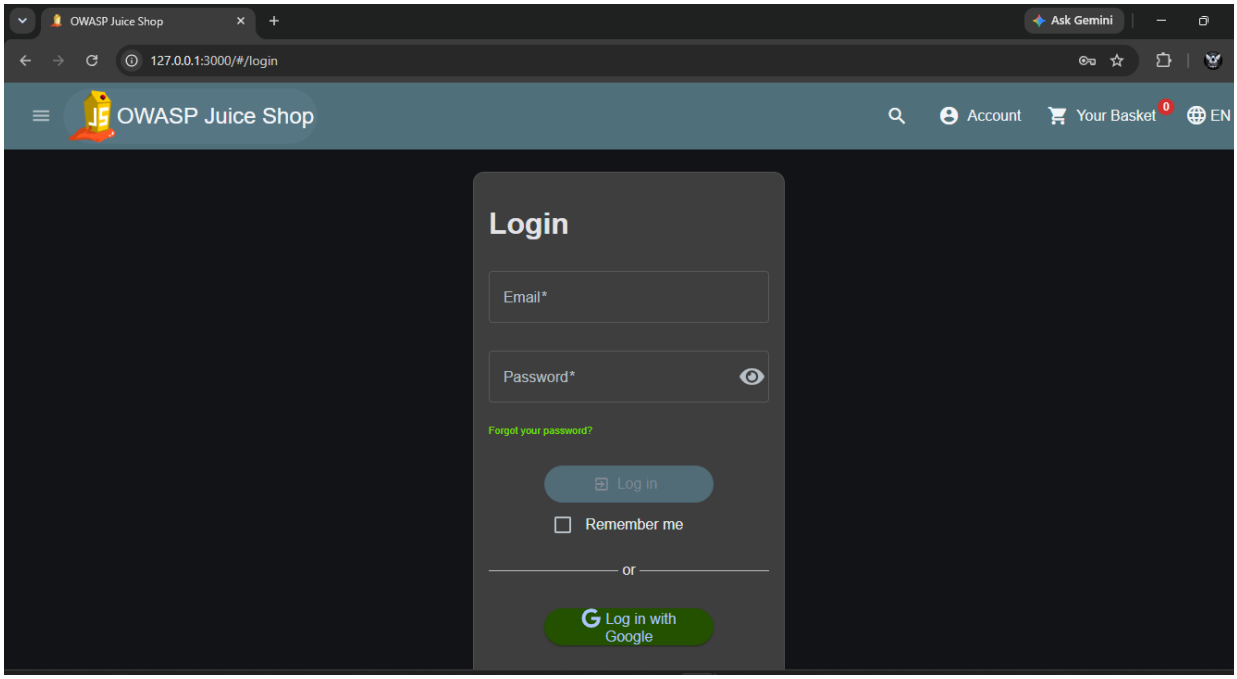
- URLs and navigation between pages.

Security observations:

- User-controlled URL parameters may affect which content is displayed.
- Product information should be handled safely.
- Restricted functions should not be accessible without proper authorization.
- User-supplied content should be safely displayed to prevent XSS.

Entry points: Navigation links, URLs, search input and product links.

2. Login form



What you can observe

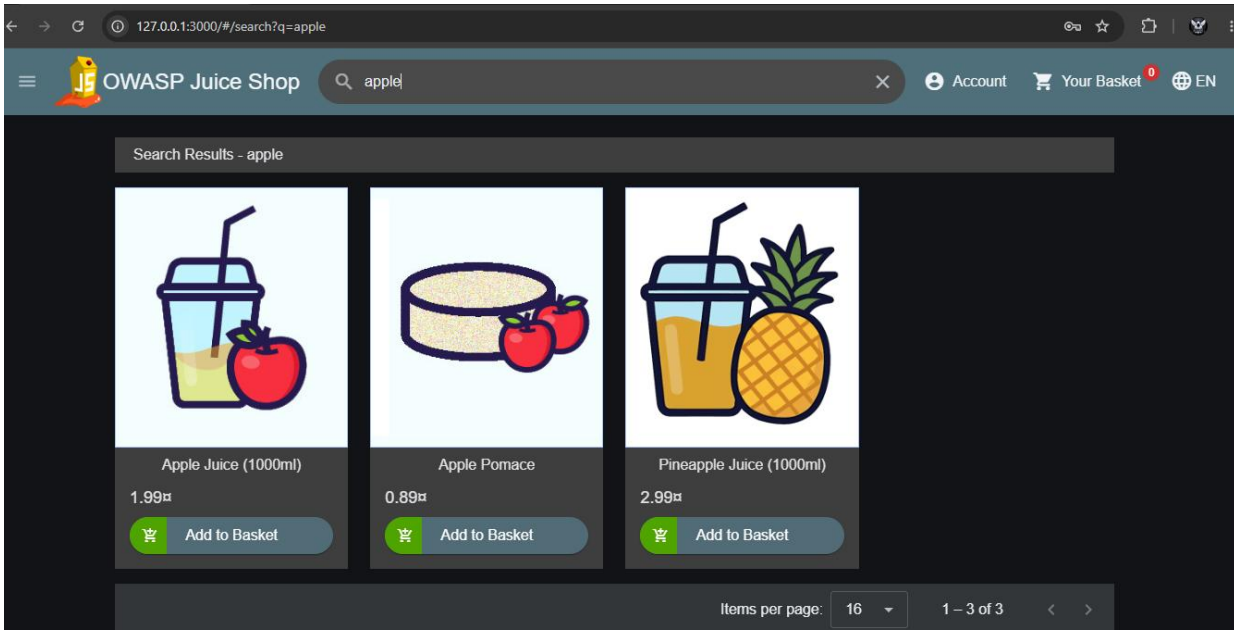
- Email field.
- Password field.
- Login button.
- Links to registration and password recovery.
- Error or success messages after submission.

Security observations:

- Does the application validate missing or incorrectly formatted fields? No.
- Are incorrect credentials handled safely? No.
- Do error messages reveal unnecessary information? Yes
- Are authenticated sessions managed securely? No
- Are protected pages restricted to authenticated users? No

Entry points: Email, password, login request and session-related cookies.

3. Search functionality



What you can observe

- Search input field.
- Search suggestions, if available.
- Product results that match the search.
- Behavior when no results are found.
- How search terms appear in requests or the URL.

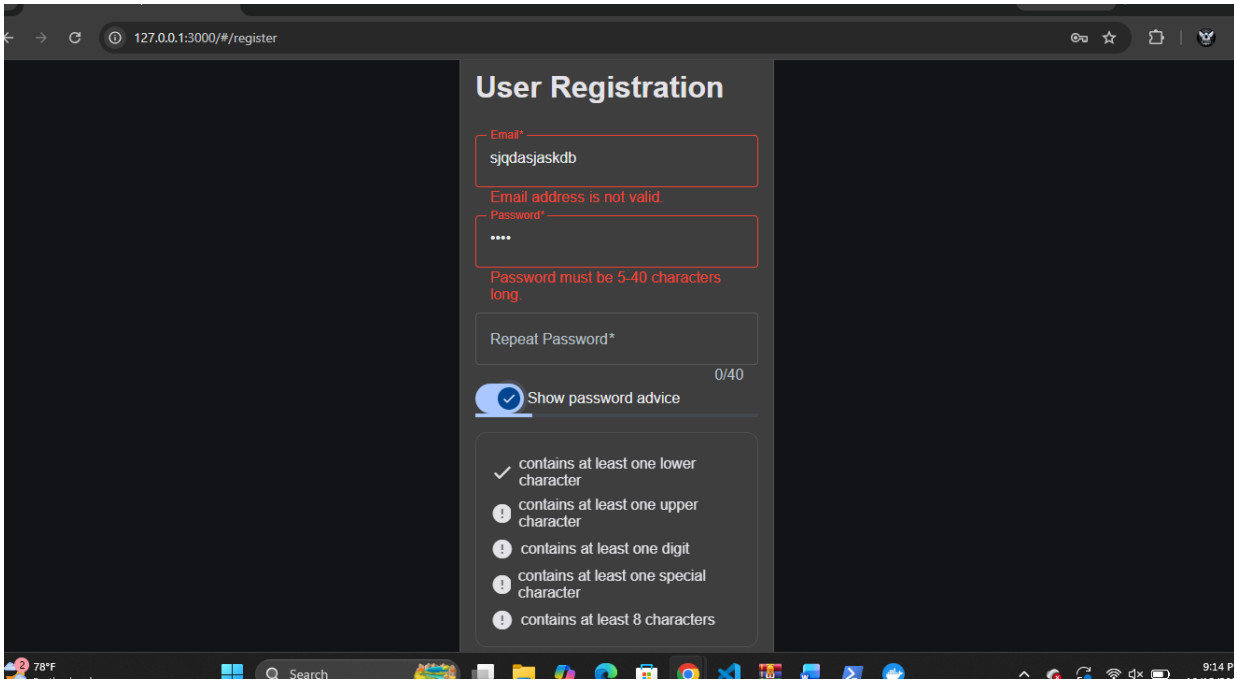
Security observations:

- Are search terms processed and displayed safely? No
- Does the application handle special characters and unexpected input? No

- Are search results consistent with the submitted query? No
- Can unusual input cause errors or unexpected behavior? Yes

Entry points: Search field, query parameters and search-related API requests.

4. Registration form



What you can observe

- Email field.
- Password and password-confirmation fields.
- Password-strength requirements.
- Security-question and answer fields.
- Registration button and validation messages.

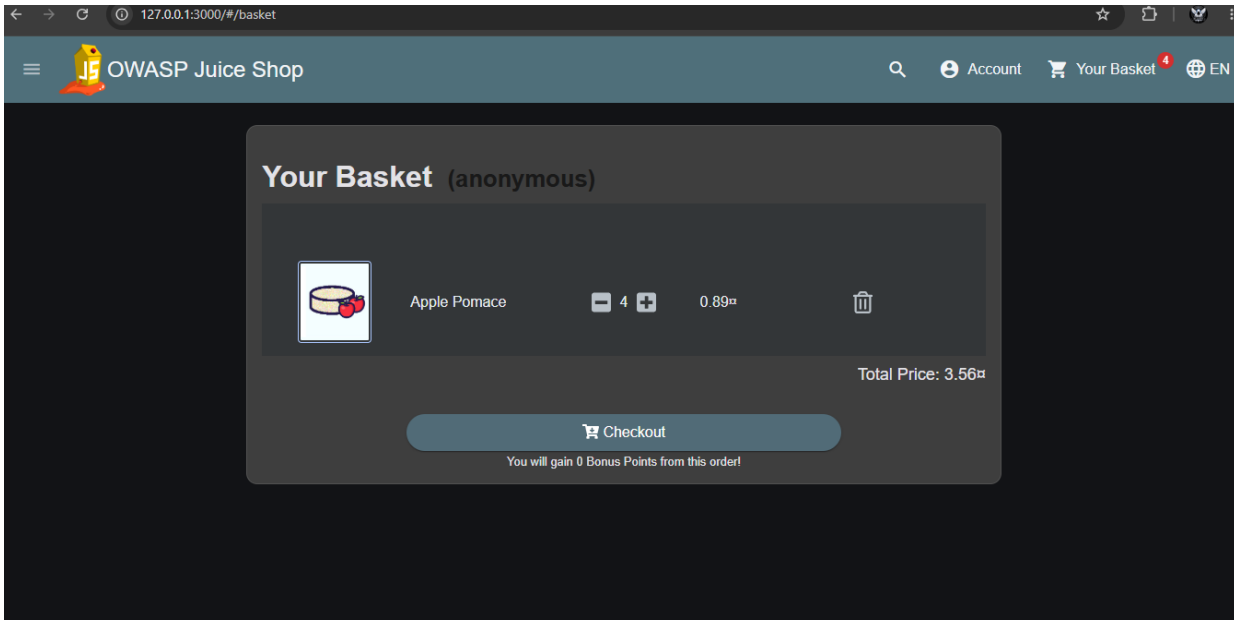
Security observations:

- Are invalid email addresses rejected? No
- Are password requirements enforced on the server? Yes
- Does the system handle mismatched passwords correctly? Kind of
- Are duplicate accounts handled appropriately? No

- Is sensitive registration information protected in transit and storage? No

Entry points: All registration fields and the account-creation API request.

5. Basket/cart



What you can observe

- Items added to the basket.
- Product quantities and prices.
- Remove-item and quantity-update controls.
- Total price calculation.
- Checkout button and checkout-related requests.

Security observations:

- Are prices and totals validated by the server? No
- Can one user access another user's basket? Yes
- Are quantity and product identifiers validated? No
- Are checkout actions protected against unauthorized requests? No
- Does the server correctly handle changes to product quantities and prices? No

4. HTTP Response

- HTTP status: 200
- Content type: text/html; charset-UTF-8
- Server header: None

5. Conclusion

The reconnaissance exercise introduced the structure and functionality of a web application. The identified entry points will help guide the design of security checks in the proposed Python-based scanner.